

Small Business Cyber Risk Assessment and Risk Register

Sanitized Governance, Risk, and Compliance portfolio case study | Wilson Hammond

Executive Summary

This portfolio lab presents a fictional small business cyber risk assessment for Green Thumb Nursery, a small plant nursery with cloud based sales operations, customer data collection, living inventory, supplier dependency, physical security monitoring, and employee safety obligations. The purpose is to demonstrate how a Governance, Risk, and Compliance analyst can convert business interview evidence into an actionable risk register, treatment plan, continuity view, and executive ready summary.

The work does not claim a real client engagement. It is framed as an academic case study that has been sanitized and rewritten for professional portfolio use. The full working register, control plan, evidence matrix, and roadmap are maintained in the companion workbook.

Scope and Assumptions

- Scope includes ordering supplies, technology, physical security, asset management, insurance, and safety.
- The organization is assumed to be a small business with limited staff and limited budget.
- The analysis favors practical controls that reduce risk without creating enterprise level complexity.
- Customer data is treated as sensitive because the point of sale process collects names, addresses, and contact details.
- Living inventory receives business continuity attention because plant health can decline quickly when supplies, water, or care processes fail.

Business Context

Green Thumb Nursery depends on a blend of technology, physical operations, human procedure, and biological inventory. Daily operations include checking moisture, monitoring grow room conditions, reviewing point of sale inventory, handling cash, securing the building, and confirming that environmental controls remain functional. Weekly operations include sales and inventory reporting, markdown decisions, pesticide treatment, and safety documentation.

Method

The risk method used a 1 to 5 likelihood scale and a 1 to 5 impact scale, with risk score calculated by multiplying likelihood by impact. The register then assigned priority, treatment response, owner, monitoring notes, Recovery Time Objective, and Recovery Point Objective relevance. The method aligns with National Institute of Standards and Technology Special Publication 800 30 risk assessment logic and National Institute of Standards and Technology Cybersecurity Framework 2.0 business context and asset understanding.

Asset and Process Inventory

Asset or Process	Business Importance	Primary Risk Area
Point of sale and customer records	Revenue, customer trust, reporting, inventory updates	Technology
Grow and Care records	Plant traceability, disease history, care documentation, inventory accuracy	Asset Management
Critical supplies	Plant health, salable inventory, business continuity	Ordering Supplies
Security cameras and safe	Employee safety, cash protection, incident evidence	Physical Security

Asset or Process	Business Importance	Primary Risk Area
Safety reports and certification records	Employee protection, compliance evidence, liability reduction	Safety
Insurance records and claim evidence	Recovery funding, loss documentation, resilience	Insurance

Risk Register Summary

Risk Area	L	I	Score	Priority	Response	RTO	RPO
Ordering Supplies	3	4	12	High	Mitigate	1 business day	Daily inventory visibility
Technology	3	5	15	High	Mitigate	4 hours	Same day reconciliation
Physical Security	3	4	12	High	Mitigate	Immediate safety response, visibility within 24 hours	Last 24 hours of footage where possible
Asset Management	4	4	16	High	Mitigate	1 business day	Daily updates preserved
Insurance	2	5	10	Medium	Transfer and Mitigate	Claim notice within 24 hours	Current monthly records
Safety	3	5	15	High	Mitigate	Immediate first aid and hazard isolation	Record completed within 24 hours

Featured Finding 1: Technology

Technology received a high score because the cloud based point of sale process sits at the intersection of revenue, customer data, sales reporting, and inventory updates. A disruption would not merely slow checkout. It could also create data reconciliation gaps and weaken customer trust.

Risk Element	Analysis
Primary exposure	Cloud based point of sale access, customer personally identifiable information, payment workflow, reporting, and inventory updates
Likely causes	Power outage, internet outage, laptop failure, hard drive failure, unavailable cloud service, delayed local information technology repair
Existing fallback	Backup laptop and paper based sales capture
Recommended treatment	Add cellular backup, require multifactor authentication, encrypt exported reports, secure outage forms in the safe, perform same day reconciliation, and define service expectations with the local provider
Recovery target	Restore transaction capability within 4 hours and reconcile same day sales before close of business

Featured Finding 2: Asset Management

Asset Management received the highest score because Green Thumb uses 2 systems to track living inventory. The same plant can move from seed or clone, to care record, to sale ready stock, to point of sale inventory, to sold or terminated status. That creates traceability, but it also creates drift risk.

Risk Element	Analysis
Primary exposure	Plant inventory, growth records, care documentation, sales records, and terminated plant records
Likely causes	Manual entry error, missed sale update, disease or neglect removal not recorded in both systems, system mismatch, or inaccurate weekly reporting
Existing control	Grow and Care software, point of sale inventory, termination reason comments, weekly reports, and reason prompt when inventory is reduced
Recommended treatment	Create daily closeout reconciliation, use unique plant identifiers, restrict inventory adjustments, review terminated items weekly, and maintain an owner approved correction log

Risk Element	Analysis
Recovery target	Correct critical inventory discrepancies within 1 business day and preserve daily transaction and plant care updates

Control Recommendation Summary

Risk Area	Recommended Control Direction	Evidence to Keep
Technology	Cellular backup, multifactor authentication, encrypted exports, secured outage forms, same day reconciliation	Outage test, access configuration, reconciliation checklist
Asset Management	Daily reconciliation, unique plant identifiers, restricted adjustments, owner approved correction log	Closeout log, identifier sample, correction log
Physical Security	Local camera storage, network power support, weekly camera testing, robbery drill documentation	Camera test log, storage setting, drill record
Safety	Safety data sheets, personal protective equipment inspection, eyewash verification, certification tracking, near miss reporting	Inspection log, certification tracker, incident record
Insurance	Annual coverage review for property, inventory, business interruption, cyber liability, workers compensation, equipment breakdown, theft, and pesticide liability	Coverage review checklist, asset records, claim packet

Continuity and Recovery View

Area	RTO	RPO	Business Reason
Technology	4 hours	Same day reconciliation	Keeps sales moving and limits customer data and reporting gaps
Asset Management	1 business day	Daily updates preserved	Prevents small mismatches from hardening into false records
Physical Security	Immediate safety response and visibility restored within 24 hours	Last 24 hours of footage where possible	Protects people first and preserves incident evidence
Safety	Immediate first aid and hazard isolation	Record completed within 24 hours	Reduces harm and protects safety evidence
Insurance	Claim notice within 24 hours	Current monthly records available	Supports recovery funding without relying on memory

Evidence Matrix

Evidence Artifact	Purpose	Review Rhythm
Risk register	Risk owner, score, response, treatment	Every formal risk review
Daily reconciliation log	Point of sale and Grow and Care agreement	Daily closeout
Outage transaction packet	Paper forms, safe storage, reconciliation record	Every point of sale outage
Camera test log	Camera status, storage status, network power support	Weekly
Safety inspection log	Personal protective equipment, eyewash access, ladder and forklift checks	Monthly or after incident
Insurance review checklist	Coverage gaps, limits, claim documents, asset records	Annual or after major change

30 60 90 Day Implementation Roadmap

Timeframe	Objective	Actions
0 to 30 days	Stabilize basic continuity	Create minimum supply threshold, secure paper transaction process, list alternate vendors, document daily reconciliation steps
31 to 60 days	Strengthen technology and evidence	Add cellular backup, enable multifactor authentication, encrypt exports, test point of sale outage workflow, create correction log

Timeframe	Objective	Actions
61 to 90 days	Formalize governance and review	Review insurance, test camera storage, conduct tabletop exercise, review safety documentation, prepare quarterly risk update

Portfolio Reflection

This lab demonstrates that useful risk work begins with the business, not the spreadsheet. The analysis required reading operational details, identifying where failure would actually hurt the organization, and recommending controls that match the size and reality of the business. The strongest lesson is that risk registers become valuable when they help leadership choose what to protect first, what evidence to keep, and how quickly the organization must recover.

Ethical Framing Statement

This project was completed as an academic case study using a fictional business scenario. The public version has been rewritten to demonstrate Governance, Risk, and Compliance analysis while removing course specific formatting, professor information, rubric language, and submission details.

References

National Institute of Standards and Technology. Guide for Conducting Risk Assessments, Special Publication 800 30 Revision 1. <https://doi.org/10.6028/NIST.SP.800-30r1>

National Institute of Standards and Technology. The NIST Cybersecurity Framework 2.0. <https://doi.org/10.6028/NIST.CSWP.29>

National Institute of Standards and Technology. Security and Privacy Controls for Information Systems and Organizations, Special Publication 800 53 Revision 5. <https://doi.org/10.6028/NIST.SP.800-53r5>

National Institute of Standards and Technology. Contingency Planning Guide for Federal Information Systems, Special Publication 800 34 Revision 1. <https://doi.org/10.6028/NIST.SP.800-34r1>